

# Cyber Threat Intelligence

## Executive Briefing

Report Date: July 01, 2026

Generated: 2026-07-01 11:04 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

### 1. Risk Statistics Summary

| Critical | High | Medium | Low | Total |
|----------|------|--------|-----|-------|
| 2        | 4    | 13     | 1   | 20    |

### 2. Executive Summary

As of July 01, 2026, the security operations team has completed an analysis of 20 identified vulnerabilities, consisting of 2 Critical, 4 High, 13 Medium, and 1 Low severity findings. This current landscape represents a heightened organizational risk posture, necessitating immediate remedial intervention to maintain a secure operating environment consistent with CVSS v3.1 industry standards. The primary threat is CVE-2026-50566, the Fission Container SecurityContext Bypass, which constitutes the highest priority due to its capacity for unauthorized privilege escalation within our containerized runtime architecture. We have transitioned to a proactive posture of immediate remediation, requiring all responsible technical units to prioritize the deployment of security patches and configuration hardening measures across identified infrastructure components without delay.

### 3. Critical Action List

- Execute immediate emergency patching of all Fission Environment Runtime and Builder components to mitigate CVE-2026-50566 by EOD today.
- Implement network segmentation and ingress filtering for the Fulcio service to neutralize the SSRF vector associated with CVE-2026-49478 within 24 hours.
- Apply the vendor-provided security patches to all @adonisjs/bodyparser deployments to resolve the parameter injection vulnerability identified in CVE-2026-48795 no later than close of business July 03, 2026.

### 4. Quick Reference: All Identified Vulnerabilities

| CVE ID         | Finding Name                         | CVSS | Severity | Urgency | CWE      |
|----------------|--------------------------------------|------|----------|---------|----------|
| CVE-2026-50566 | Fission Container SecurityContext... | 10.0 | Critical | 99/100  | CWE-250  |
| CVE-2026-49478 | SSRF and Token Leakage in Fulcio     | 10.0 | Critical | 78/100  | CWE-918  |
| CVE-2026-48795 | Incomplete Fix for Parameter Inje... | 8.6  | High     | 77/100  | CWE-1321 |

|                |                                      |     |        |        |         |
|----------------|--------------------------------------|-----|--------|--------|---------|
| CVE-2026-48592 | Missing Authorization in Oban_Web    | 6.5 | Medium | 69/100 | CWE-862 |
| CVE-2026-48593 | Memory Exhaustion in Oban_Web Cron   | 6.5 | Medium | 69/100 | CWE-400 |
| CVE-2025-10996 | Heap Buffer Overflow in Open Babel   | 7.8 | High   | 65/100 | CWE-119 |
| CVE-2025-10995 | Out-of-Bounds Write in Zipstream     | 7.8 | High   | 65/100 | CWE-787 |
| CVE-2025-10994 | Use-After-Free in Open Babel         | 7.8 | High   | 65/100 | CWE-119 |
| CVE-2026-3408  | NULL Pointer Dereference in Open ... | 5.5 | Medium | 60/100 | CWE-476 |
| CVE-2026-2705  | NULL Pointer Dereference in MOL2 ... | 5.5 | Medium | 60/100 | CWE-119 |
| CVE-2026-48808 | Twig Sandbox Allowlist Bypass via... | 5.4 | Medium | 59/100 | CWE-693 |
| CVE-2026-48807 | Twig Sandbox Policy Bypass via Tr... | 5.4 | Medium | 59/100 | CWE-693 |
| CVE-2026-48806 | Twig Sandbox Bypass via Dynamic K... | 5.4 | Medium | 59/100 | CWE-693 |
| CVE-2026-50565 | Insecure Token Mounting in Fission   | 4.9 | Medium | 54/100 | CWE-250 |
| CVE-2026-49835 | Denial of Service in Sigstore Tim... | 5.9 | Medium | 53/100 | CWE-770 |
| CVE-2026-2704  | Out-of-Bounds Read in CIF Parser     | 4.4 | Medium | 50/100 | CWE-119 |
| CVE-2026-48796 | Path Traversal in CefSharp.Common    | 5.3 | Medium | 48/100 | CWE-22  |
| CVE-2026-55219 | Race Condition in Paymenter Credi... | 5.3 | Medium | 43/100 | CWE-362 |
| CVE-2026-49820 | Open Redirect via Path Normalizat... | 6.1 | Medium | 42/100 | CWE-601 |
| CVE-2026-48805 | Twig Sandbox State Regression        | 3.1 | Low    | 28/100 | CWE-693 |

5. Detailed Vulnerability Findings

CVE-2026-50566

Finding: Fission Container SecurityContext Bypass

CVSS v3.1 Score: 10.0 | Severity: Critical | Urgency Score: 99/100 | CWE: CWE-250

MITRE ATT&CK: T1611, T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

|                     |         |
|---------------------|---------|
| Attack Vector       | Network |
| Privileges Required | None    |
| Scope               | Changed |
| Integrity Impact    | High    |

|                        |      |
|------------------------|------|
| Attack Complexity      | Low  |
| User Interaction       | None |
| Confidentiality Impact | High |
| Availability Impact    | High |

Description:

Fission contains a vulnerability in its Environment Runtime and Builder SecurityContext management that permits privileged pod creation. Attackers can bypass default isolation policies, allowing pods to run with elevated permissions. This grants unauthorized access to the underlying Kubernetes host or container environment.

Proof of Concept (PoC):

The attacker creates a malicious Fission environment definition that requests a privileged security context. The Fission controller fails to validate the container spec properly, resulting in a pod being deployed with host-level privileges on the cluster.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50566>  
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50566>

CVE-2026-49478

Finding: SSRF and Token Leakage in Fulcio

CVSS v3.1 Score: 10.0 | Severity: Critical | Urgency Score: 78/100 | CWE: CWE-918

MITRE ATT&CK: T1510, T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N

|                     |         |
|---------------------|---------|
| Attack Vector       | Network |
| Privileges Required | None    |
| Scope               | Changed |
| Integrity Impact    | High    |

|                        |      |
|------------------------|------|
| Attack Complexity      | Low  |
| User Interaction       | None |
| Confidentiality Impact | High |
| Availability Impact    | None |

Description:

Fulcio contains an SSRF vulnerability within its OIDC discovery redirect logic, enabling attackers to perform JWKS substitution and leak Kubernetes service account tokens. The flaw originates from the failure to restrict redirect targets during issuer verification. This significantly compromises the confidentiality of the environment.

Proof of Concept (PoC):

The attacker submits a request to the Fulcio issuer discovery endpoint with a malicious redirect URL. Fulcio follows the redirect to an attacker-controlled server, which responds with a fake JWKS. The resulting token leakage allows the attacker to impersonate identities.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49478>  
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49478>

CVE-2026-48795

Finding: Incomplete Fix for Parameter Injection

CVSS v3.1 Score: 8.6 | Severity: High | Urgency Score: 77/100 | CWE: CWE-1321

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L

|                     |           |
|---------------------|-----------|
| Attack Vector       | Network   |
| Privileges Required | None      |
| Scope               | Unchanged |
| Integrity Impact    | High      |

|                        |      |
|------------------------|------|
| Attack Complexity      | Low  |
| User Interaction       | None |
| Confidentiality Impact | Low  |
| Availability Impact    | Low  |

Description:

@adonisjs/bodyparser contains an incomplete fix for a parameter injection vulnerability (CVE-2026-25754), leading to potential mass assignment attacks. The filter for input parameters is insufficiently restrictive, allowing attackers to overwrite internal object state. This integrity vulnerability can lead to privilege escalation or application logic manipulation.

Proof of Concept (PoC):

The attacker sends a JSON payload to the application endpoint containing nested object keys such as {'\_\_proto\_\_':

{'admin': true}}. The bodyparser fails to ignore or sanitize these keys, allowing the properties to be injected into the application configuration.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48795>  
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48795>

CVE-2026-48592

Finding: Missing Authorization in Oban\_Web

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 69/100 | CWE: CWE-862

MITRE ATT&CK: T1562

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N

|                     |           |
|---------------------|-----------|
| Attack Vector       | Network   |
| Privileges Required | Low       |
| Scope               | Unchanged |
| Integrity Impact    | High      |

|                        |      |
|------------------------|------|
| Attack Complexity      | Low  |
| User Interaction       | None |
| Confidentiality Impact | None |
| Availability Impact    | None |

Description:

The oban\_web application lacks proper authorization checks on the 'save-job' event handler, allowing any authenticated user to modify queued jobs. This vulnerability arises from the failure to verify ownership or administrative permissions for the request. This can be exploited to manipulate or delete jobs, violating application integrity.

Proof of Concept (PoC):

An authenticated, non-privileged user submits a request to the 'save-job' event handler with an ID of a job belonging to another user. The server updates the job settings without verifying that the requester has administrative authorization.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48592>  
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48592>

CVE-2026-48593

Finding: Memory Exhaustion in Oban\_Web Cron

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 69/100 | CWE: CWE-400

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H

|                     |           |
|---------------------|-----------|
| Attack Vector       | Network   |
| Privileges Required | Low       |
| Scope               | Unchanged |
| Integrity Impact    | None      |

|                        |      |
|------------------------|------|
| Attack Complexity      | Low  |
| User Interaction       | None |
| Confidentiality Impact | None |
| Availability Impact    | High |

Description:

Oban\_web is vulnerable to a denial-of-service attack due to unbounded range expansion in the cron description feature. By submitting a crafted cron expression, an attacker can force the application to generate an excessive number of scheduling instances. This leads to memory exhaustion and degrades application availability.

Proof of Concept (PoC):

The attacker submits a request with an extremely long range in the cron description field. The server's logic attempts to

pre-calculate all execution times for this range in memory, resulting in excessive heap allocation and a crash.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48593>  
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48593>

CVE-2025-10996

Finding: Heap Buffer Overflow in Open Babel

CVSS v3.1 Score: 7.8 | Severity: High | Urgency Score: 65/100 | CWE: CWE-119

MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

|                     |           |
|---------------------|-----------|
| Attack Vector       | Local     |
| Privileges Required | None      |
| Scope               | Unchanged |
| Integrity Impact    | High      |

|                        |          |
|------------------------|----------|
| Attack Complexity      | Low      |
| User Interaction       | Required |
| Confidentiality Impact | High     |
| Availability Impact    | High     |

Description:

Open Babel exhibits a heap buffer overflow vulnerability within the OBSmilesParser::ParseSmiles method. The issue arises from improper bounds checking when processing malicious SMILES formatted strings, leading to memory corruption. This vulnerability allows an attacker to potentially execute arbitrary code or cause a crash, compromising system integrity and availability.

Proof of Concept (PoC):

A user must open a maliciously crafted chemical structure file using Open Babel. The parser encounters a SMILES string exceeding the allocated buffer size in OBSmilesParser::ParseSmiles. The heap memory is corrupted, allowing the attacker to control the execution flow.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2025-10996>  
Ref: <https://www.cve.org/CVERecord?id=CVE-2025-10996>

CVE-2025-10995

Finding: Out-of-Bounds Write in Zipstream

CVSS v3.1 Score: 7.8 | Severity: High | Urgency Score: 65/100 | CWE: CWE-787

MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

|                     |           |
|---------------------|-----------|
| Attack Vector       | Local     |
| Privileges Required | None      |
| Scope               | Unchanged |
| Integrity Impact    | High      |

|                        |          |
|------------------------|----------|
| Attack Complexity      | Low      |
| User Interaction       | Required |
| Confidentiality Impact | High     |
| Availability Impact    | High     |

Description:

The zipstream library component within Open Babel contains an out-of-bounds write vulnerability due to overlapping memory copies in basic\_unzip\_streambuf::underflow. This flaw occurs because the input data length is not sufficiently validated against destination buffer boundaries. Successful exploitation may lead to memory corruption, potentially impacting the confidentiality and integrity of the application.

Proof of Concept (PoC):

An attacker provides a specially crafted compressed archive to an application using Open Babel's zipstream component. The application calls `basic_unzip_streambuf::underflow`, triggering an overlapping memcpy. This memory overwrite allows for arbitrary code execution within the process context.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2025-10995>  
Ref: <https://www.cve.org/CVERecord?id=CVE-2025-10995>

CVE-2025-10994

Finding: Use-After-Free in Open Babel

CVSS v3.1 Score: 7.8 | Severity: High | Urgency Score: 65/100 | CWE: CWE-119

MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

|                     |           |
|---------------------|-----------|
| Attack Vector       | Local     |
| Privileges Required | None      |
| Scope               | Unchanged |
| Integrity Impact    | High      |

|                        |          |
|------------------------|----------|
| Attack Complexity      | Low      |
| User Interaction       | Required |
| Confidentiality Impact | High     |
| Availability Impact    | High     |

Description:

Open Babel is susceptible to a use-after-free vulnerability within the `GAMESSOutputFormat::ReadMolecule` function. This flaw occurs when memory is released prematurely while still being referenced during molecule parsing, leading to undefined behavior upon subsequent access. An attacker can leverage this to crash the application or potentially execute arbitrary code.

Proof of Concept (PoC):

The attacker supplies a malformed GAMESS output file containing specific structural directives. Open Babel reads the file, triggering the `GAMESSOutputFormat::ReadMolecule` function to allocate and then free an object that is later accessed. This triggers a use-after-free, facilitating memory manipulation.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2025-10994>  
Ref: <https://www.cve.org/CVERecord?id=CVE-2025-10994>

CVE-2026-3408

Finding: NULL Pointer Dereference in Open Babel

CVSS v3.1 Score: 5.5 | Severity: Medium | Urgency Score: 60/100 | CWE: CWE-476

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H

|                     |           |
|---------------------|-----------|
| Attack Vector       | Local     |
| Privileges Required | None      |
| Scope               | Unchanged |
| Integrity Impact    | None      |

|                        |          |
|------------------------|----------|
| Attack Complexity      | Low      |
| User Interaction       | Required |
| Confidentiality Impact | None     |
| Availability Impact    | High     |

Description:

A NULL pointer dereference vulnerability exists in the CDXML parser within Open Babel's `OBAAtom::GetExplicitValence`

function. This occurs when an unexpected atom structure causes a pointer lookup to fail, and the code attempts to dereference the resulting NULL address. This can lead to a denial-of-service condition by crashing the application.

#### Proof of Concept (PoC):

A user uploads a malformed CDXML file for conversion. The `OBAAtom::GetExplicitValence` method is invoked on an uninitialized atom object, resulting in a NULL dereference. The process terminates immediately, resulting in a service outage.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-3408>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-3408>

## CVE-2026-2705

### Finding: NULL Pointer Dereference in MOL2 Parser

CVSS v3.1 Score: 5.5 | Severity: Medium | Urgency Score: 60/100 | CWE: CWE-119

MITRE ATT&CK: T1499

#### CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H

|                     |           |
|---------------------|-----------|
| Attack Vector       | Local     |
| Privileges Required | None      |
| Scope               | Unchanged |
| Integrity Impact    | None      |

|                        |          |
|------------------------|----------|
| Attack Complexity      | Low      |
| User Interaction       | Required |
| Confidentiality Impact | None     |
| Availability Impact    | High     |

#### Description:

The MOL2 parsing logic in Open Babel contains a NULL pointer dereference within the `OBAAtom::SetFormalCharge` function. This vulnerability is triggered when invalid file content causes an internal object to remain uninitialized. An attacker providing a specifically crafted MOL2 file can trigger an application crash, causing a local denial-of-service.

#### Proof of Concept (PoC):

An attacker creates a MOL2 file missing essential atom definition tokens. The processing engine attempts to set a formal charge on a null atom reference, causing a segmentation fault. This effectively terminates the application.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-2705>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-2705>

## CVE-2026-48808

### Finding: Twig Sandbox Allowlist Bypass via Column Filter

CVSS v3.1 Score: 5.4 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-693

MITRE ATT&CK: T1210

#### CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N

|                     |           |
|---------------------|-----------|
| Attack Vector       | Network   |
| Privileges Required | Low       |
| Scope               | Unchanged |
| Integrity Impact    | Low       |

|                        |      |
|------------------------|------|
| Attack Complexity      | Low  |
| User Interaction       | None |
| Confidentiality Impact | Low  |
| Availability Impact    | None |

#### Description:

The Twig template engine's sandbox component suffers from an allowlist bypass vulnerability in the 'column' filter. An

attacker can circumvent the SourcePolicyInterface by injecting unauthorized properties into the template rendering flow. This allows potential unauthorized access to object properties that should be restricted.

#### Proof of Concept (PoC):

An authenticated user injects a template block using the column filter with a nested object call. The sandbox logic incorrectly validates the property access chain. This permits the attacker to retrieve sensitive properties that are otherwise restricted by policy.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48808>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48808>

## CVE-2026-48807

### Finding: Twig Sandbox Policy Bypass via Traversable

CVSS v3.1 Score: 5.4 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-693

MITRE ATT&CK: T1210

#### CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N

|                     |           |
|---------------------|-----------|
| Attack Vector       | Network   |
| Privileges Required | Low       |
| Scope               | Unchanged |
| Integrity Impact    | Low       |

|                        |      |
|------------------------|------|
| Attack Complexity      | Low  |
| User Interaction       | None |
| Confidentiality Impact | Low  |
| Availability Impact    | None |

#### Description:

Twig's sandbox mechanism is vulnerable to a policy bypass via the use of 'Traversable' objects within 'join' and 'replace' filters. The sandbox incorrectly evaluates the string representation of these objects, permitting execution of unintended logic. This vulnerability compromises the sandbox isolation model.

#### Proof of Concept (PoC):

The attacker provides a template containing a Traversable object to a filter like 'replace'. The engine calls `__toString()` on the object during the filtering process, bypassing the sandbox policy checks. This allows the attacker to access non-whitelisted string data.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48807>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48807>

## CVE-2026-48806

### Finding: Twig Sandbox Bypass via Dynamic Keys

CVSS v3.1 Score: 5.4 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-693

MITRE ATT&CK: T1210

#### CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N

|                     |           |
|---------------------|-----------|
| Attack Vector       | Network   |
| Privileges Required | Low       |
| Scope               | Unchanged |
| Integrity Impact    | Low       |

|                        |      |
|------------------------|------|
| Attack Complexity      | Low  |
| User Interaction       | None |
| Confidentiality Impact | Low  |
| Availability Impact    | None |

#### Description:



Twig's sandbox environment contains a policy bypass vulnerability involving dynamic mapping keys during template rendering. By manipulating these keys, an attacker can coerce the sandbox into accessing restricted objects via the `__toString()` magic method. This circumvents the core security policy enforced on templating variables.

Proof of Concept (PoC):

An attacker creates a template array with keys that trigger objects to be converted to strings. The twig sandbox engine performs the cast inside the rendering context before policy verification. The resulting string is displayed in the output, allowing access to protected metadata.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48806>  
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48806>

CVE-2026-50565

Finding: Insecure Token Mounting in Fission

CVSS v3.1 Score: 4.9 | Severity: Medium | Urgency Score: 54/100 | CWE: CWE-250

MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:N/A:N

|                     |           |
|---------------------|-----------|
| Attack Vector       | Network   |
| Privileges Required | High      |
| Scope               | Unchanged |
| Integrity Impact    | None      |

|                        |      |
|------------------------|------|
| Attack Complexity      | Low  |
| User Interaction       | None |
| Confidentiality Impact | High |
| Availability Impact    | None |

Description:

Fission builder pods incorrectly auto-mount the 'fission-builder' ServiceAccount token in user-supplied builder containers. This creates an escalation path where an attacker can utilize the token to perform unauthorized cluster-level operations. The issue stems from excessive permission scoping in the pod template.

Proof of Concept (PoC):

An attacker with permission to define Fission environments creates a new environment. When the builder pod spawns, the attacker accesses the filesystem to retrieve the mounted ServiceAccount token, subsequently using it for unauthorized Kubernetes API queries.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50565>  
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50565>

CVE-2026-49835

Finding: Denial of Service in Sigstore Timestamp Authority

CVSS v3.1 Score: 5.9 | Severity: Medium | Urgency Score: 53/100 | CWE: CWE-770

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H

|                     |           |
|---------------------|-----------|
| Attack Vector       | Network   |
| Privileges Required | None      |
| Scope               | Unchanged |
| Integrity Impact    | None      |

|                        |      |
|------------------------|------|
| Attack Complexity      | High |
| User Interaction       | None |
| Confidentiality Impact | None |
| Availability Impact    | High |

**Description:**

The Sigstore Timestamp Authority is susceptible to a denial-of-service vulnerability due to unbounded metric label cardinality. An attacker can submit requests containing a high volume of unique labels, leading to memory exhaustion and eventual service failure. This impacts the availability of the timestamping service.

**Proof of Concept (PoC):**

An unauthenticated attacker sends a massive stream of requests to the metrics endpoint, each with unique, randomly generated label key-value pairs. The server attempts to index each unique metric in memory. The process exceeds available RAM, causing a crash.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49835>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49835>

**CVE-2026-2704****Finding: Out-of-Bounds Read in CIF Parser**

**CVSS v3.1 Score: 4.4 | Severity: Medium | Urgency Score: 50/100 | CWE: CWE-119**

**MITRE ATT&CK: T1592**

**CVSS v3.1 Scoring Criteria:**

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:L/I:N/A:L

|                     |           |
|---------------------|-----------|
| Attack Vector       | Local     |
| Privileges Required | None      |
| Scope               | Unchanged |
| Integrity Impact    | None      |

|                        |          |
|------------------------|----------|
| Attack Complexity      | Low      |
| User Interaction       | Required |
| Confidentiality Impact | Low      |
| Availability Impact    | Low      |

**Description:**

Open Babel's CIF parser contains an out-of-bounds read vulnerability in the transform3d::DescribeAsString function. This occurs due to improper index validation when processing string representations of transformation matrices. This flaw may allow an attacker to leak sensitive memory contents to an output stream.

**Proof of Concept (PoC):**

The attacker provides a CIF file containing a maliciously formatted transformation matrix. When Open Babel attempts to format this as a string, it reads past the end of the buffer, potentially leaking adjacent memory data in the output.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-2704>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-2704>

**CVE-2026-48796****Finding: Path Traversal in CefSharp.Common**

**CVSS v3.1 Score: 5.3 | Severity: Medium | Urgency Score: 48/100 | CWE: CWE-22**

**MITRE ATT&CK: T1083**

**CVSS v3.1 Scoring Criteria:**

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

|                     |           |
|---------------------|-----------|
| Attack Vector       | Network   |
| Privileges Required | None      |
| Scope               | Unchanged |
| Integrity Impact    | None      |

|                        |      |
|------------------------|------|
| Attack Complexity      | Low  |
| User Interaction       | None |
| Confidentiality Impact | Low  |
| Availability Impact    | None |

Description:

CefSharp.Common is vulnerable to a path traversal attack via the FolderSchemeHandlerFactory due to insufficient path boundary checking. An attacker can escape the designated root folder to access sensitive system files or application configuration. This poses a significant risk to file-based confidentiality.

Proof of Concept (PoC):

An attacker requests a resource using a crafted path containing relative traversal sequences like '..\..\\" through the FolderSchemeHandlerFactory. The server fails to normalize the path correctly, allowing access to files outside the permitted folder scope.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48796>  
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48796>

CVE-2026-55219

Finding: Race Condition in Paymenter Credit Transaction

CVSS v3.1 Score: 5.3 | Severity: Medium | Urgency Score: 43/100 | CWE: CWE-362

MITRE ATT&CK: T1496

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:N/I:H/A:N

|                     |           |
|---------------------|-----------|
| Attack Vector       | Network   |
| Privileges Required | Low       |
| Scope               | Unchanged |
| Integrity Impact    | High      |

|                        |      |
|------------------------|------|
| Attack Complexity      | High |
| User Interaction       | None |
| Confidentiality Impact | None |
| Availability Impact    | None |

Description:

Paymenter contains a race condition in the payWithCredit() function that enables unauthorized credit double-spending. The vulnerability exists due to a lack of atomic locking or database transaction isolation during the credit balance check and update phase. Attackers can exploit this to perform multiple transactions simultaneously, resulting in a loss of financial integrity.

Proof of Concept (PoC):

An authenticated user initiates multiple near-simultaneous POST requests to the credit payment endpoint. The server processes these requests in parallel, bypassing the balance check before the previous deduction is committed. This results in the credit account balance being used multiple times.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55219>  
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55219>

CVE-2026-49820

Finding: Open Redirect via Path Normalization

CVSS v3.1 Score: 6.1 | Severity: Medium | Urgency Score: 42/100 | CWE: CWE-601

MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

|                     |         |
|---------------------|---------|
| Attack Vector       | Network |
| Privileges Required | None    |

|                   |          |
|-------------------|----------|
| Attack Complexity | Low      |
| User Interaction  | Required |

|                  |         |
|------------------|---------|
| Scope            | Changed |
| Integrity Impact | Low     |

|                        |      |
|------------------------|------|
| Confidentiality Impact | Low  |
| Availability Impact    | None |

Description:

Probo contains an open redirect vulnerability that can be bypassed using path normalization techniques. An attacker can craft a URL that, after normalization by the server, redirects the user to an arbitrary external domain. This vulnerability facilitates phishing and credibility attacks against users.

Proof of Concept (PoC):

An attacker sends a link pointing to a legitimate Probo endpoint followed by a double-encoded path. The server normalizes this to an external URL and redirects the victim, masking the destination host.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49820>  
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49820>

CVE-2026-48805

Finding: Twig Sandbox State Regression

CVSS v3.1 Score: 3.1 | Severity: Low | Urgency Score: 28/100 | CWE: CWE-693

MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:N/A:N

|                     |           |
|---------------------|-----------|
| Attack Vector       | Network   |
| Privileges Required | Low       |
| Scope               | Unchanged |
| Integrity Impact    | None      |

|                        |      |
|------------------------|------|
| Attack Complexity      | High |
| User Interaction       | None |
| Confidentiality Impact | Low  |
| Availability Impact    | None |

Description:

A state regression exists in the deprecated internal wrappers of Twig within 'src/Resources/core.php', weakening the sandbox protection. The regression allows previously blocked internal calls to proceed, potentially exposing sensitive application logic. This vulnerability reduces the effective security posture of template isolation.

Proof of Concept (PoC):

The attacker targets an application using an outdated internal wrapper call in Twig. By using a crafted template to invoke this deprecated path, the sandbox fails to enforce access restrictions. The attacker confirms the bypass by observing the return value of an unauthorized internal function.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48805>  
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48805>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from the GitHub Advisory Database and cross-references active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data

into this executive briefing. All CVE identifiers, CVSS scores, and CWE mappings are sourced directly from official databases and are verifiable via the references provided in Section 5. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

**Primary Data Sources:**

- GitHub Advisory Database -- <https://github.com/advisories>
- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>